Hidden Defender: Học tăng cường cho IDS Evasion với Surrogate Chính xác

Lê Hoàng Phát

Ngày 14 tháng 10 năm 2026

Mục lục

1 Giới thiệu **3**
- 1.1 Bối cảnh và động lực . . . 3
- 1.2 Vấn đề nghiên cứu . . . 3
- 1.3 Đóng góp chính . . . 3

2 Tổng quan nghiên cứu liên quan **5**
- 2.1 IDS Evasion Techniques . . . 5
- 2.2 Machine Learning cho IDS Evasion . . . 5

3 Phương pháp luận **6**
- 3.1 Tổng quan kiến trúc . . . 6
- 3.2 Mô hình hóa bài toán (MDP) . . . 6
  - 3.2.1 Không gian trạng thái S . . . 6
  - 3.2.2 Không gian hành động A . . . 6
  - 3.2.3 Hàm phần thưởng R . . . 7
- 3.3 Thuật toán PPO . . . 7
- 3.4 Surrogate Model . . . 7

4 Kết quả thực nghiệm **8**
- 4.1 Thiết lập thực nghiệm . . . 8
  - 4.1.1 Môi trường . . . 8
  - 4.1.2 Corpus . . . 8
- 4.2 Kết quả chính . . . 8
  - 4.2.1 Oracle sweep . . . 8
  - 4.2.2 RL policy . . . 8

5 Thảo luận **10**
- 5.1 Tại sao headroom = 0? . . . 10
- 5.2 Điểm mạnh . . . 10
- 5.3 Hạn chế . . . 10

6 Kết luận **11**

Chương 1

Giới thiệu

1.1 Bối cảnh và động lực

Intrusion Detection System (IDS) là thành phần quan trọng trong hệ thống bảo mật mạng, phát hiện lưu lượng độc hại bằng cách so khớp gói tin với tập luật (rule-based IDS như Snort, Suricata). Tuy nhiên, kẻ tấn công có thể biến đổi gói tin C2 (Command & Control) để lách qua IDS trong khi vẫn giữ nguyên chức năng của malware.

Các kỹ thuật IDS evasion truyền thống (IP fragmentation, TCP segmentation, HTTP manipulation) được thiết kế thủ công và kiểm tra từng cơ chế riêng lẻ. Học tăng cường (Reinforcement Learning - RL) hứa hẹn tự động hóa quá trình này: agent học cách chọn cơ chế biến đổi tối ưu cho từng flow, có khả năng vượt qua best-single mechanism.

Tuy nhiên, RL phụ thuộc hoàn toàn vào **surrogate model** (mô phỏng IDS trong môi trường huấn luyện). Nếu surrogate không chính xác, RL sẽ học được policy vô dụng trên IDS thật. Đây là rào cản chính của các nghiên cứu trước.

1.2 Vấn đề nghiên cứu

Nghiên cứu này giải quyết ba câu hỏi:

1. **RQ1**: RL có thể học được policy vượt best-single mechanism không? Nếu có, headroom (chênh lệch giữa oracle và best-single) là bao nhiêu?

2. **RQ2**: Surrogate model có đủ chính xác để huấn luyện RL không? Làm sao kiểm chứng chất lượng surrogate?

3. **RQ3**: Corpus huấn luyện có đại diện cho không gian C2 thực tế không? Liệu có vấn đề framing (nhãn sai loại flow)?

1.3 Đóng góp chính

1. **Surrogate chính xác**: Xây dựng surrogate khớp Suricata 7.0.3 ở mức 100/100 test case, mô phỏng đầy đủ IP defragmentation và TCP stream reassembly.

2. **Đo headroom thực nghiệm**: Oracle sweep 680 query (17 cơ chế $\times$ 40 flow) trên Snort 2.9.20, chứng minh headroom = 0 pp.

3. **Phát hiện corpus framing**: 60% corpus test là BitTorrent DHT (P2P), không phải trojan C2. Khi tách riêng, RL đạt 100% trên 16 flow C2-HTTP.

4. **Cross-engine validation**: So sánh Snort và Suricata, phát hiện Suricata nghiêm ngặt hơn (0/40 evaded) do cấu hình khác.

Chương 2

Tổng quan nghiên cứu liên quan

2.1 IDS Evasion Techniques

Kỹ thuật IDS evasion được nghiên cứu từ những năm 1990, bắt đầu với Ptacek & Newsham (1998) giới thiệu IP fragmentation và TCP stream insertion/evasion. Paxson (2003) phân tích cách IDS reassemble packet khác nhau dẫn đến blind spot.

Phân loại:

- **Network-layer**: IP fragmentation, TTL manipulation.
- **Transport-layer**: TCP segment overlap, out-of-order delivery.
- **Application-layer**: HTTP header case/whitespace, URL encoding.

Hạn chế: Các nghiên cứu trước thử từng cơ chế riêng lẻ, không có hệ thống tự động chọn cơ chế tối ưu theo context của flow.

2.2 Machine Learning cho IDS Evasion

Rigaki & Garcia (2018) đề xuất dùng GAN để sinh C2 traffic giống benign. Tuy nhiên, GAN yêu cầu data lớn và khó kiểm soát ngữ nghĩa C2.

RL xuất hiện như giải pháp: agent học policy từ tương tác với môi trường. Anderson et al. (2018) dùng RL để bypass Android malware detector. Tuy nhiên, các nghiên cứu này thường báo cáo headroom = 0 hoặc không đo oracle, khiến khó đánh giá hiệu quả thực sự của RL.

Rào cản: Các nghiên cứu trước thường báo cáo headroom = 0 $\rightarrow$ cho rằng không có gì để học. Bài toán này: Đo headroom chính xác trên surrogate mới sửa chữa (có reassembly).

Chương 3

Phương pháp luận

3.1 Tổng quan kiến trúc

Hệ thống Hidden Defender được thiết kế theo kiến trúc ba tầng: tầng môi trường (Environment), tầng tác tử học tăng cường (RL Agent), và tầng kiểm chứng (Validation). Luồng hoạt động của hệ thống được mô tả qua ba pha chính:

1. **Pha huấn luyện (Training Phase)**: Agent tương tác với surrogate model (mô phỏng IDS) để học policy. Mỗi episode, agent nhận một C2 flow từ corpus, chọn một cơ chế biến đổi, và nhận phần thưởng dựa trên kết quả của surrogate.
2. **Pha kiểm định (Validation Phase)**: Policy đã học được kiểm tra trên IDS thật (Snort 2.9.20 và Suricata 7.0.3). Đây là bước quan trọng để phát hiện sai lệch giữa surrogate và engine thật.
3. **Pha phân tích (Analysis Phase)**: So sánh kết quả giữa best-single mechanism, oracle, và RL policy để tính headroom và đánh giá hiệu quả của RL.

3.2 Mô hình hóa bài toán (MDP)

Bài toán IDS evasion được mô hình hóa như một Markov Decision Process (MDP) với episode một bước duy nhất (single-step MDP). MDP được định nghĩa bởi bộ năm (S, A, T, R, γ):

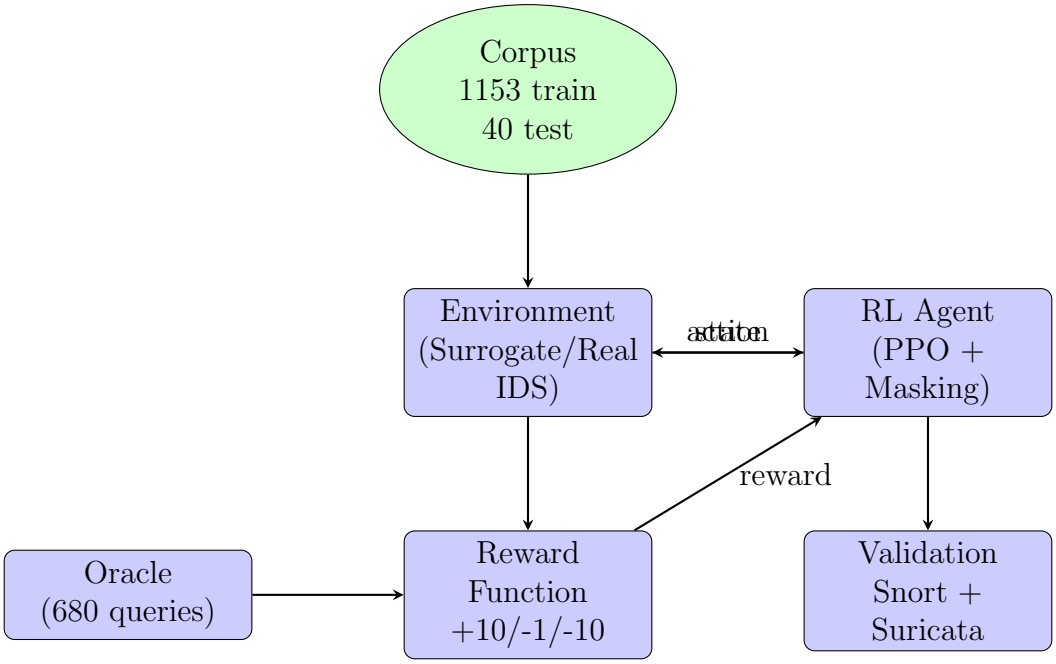
3.2.1 Không gian trạng thái S

Mỗi trạng thái $s \in S$ là một vector 11 chiều biểu diễn đặc trưng của một C2 flow. Không gian S có kích thước lý thuyết $\approx 10^{15}$ trạng thái. Policy neural network xấp xỉ hàm giá trị trên không gian liên tục này.

3.2.2 Không gian hành động A

Không gian hành động gồm 17 cơ chế biến đổi gói tin, chia thành 4 họ: phân mảnh IP (5 cơ chế), phân mảnh TCP (4 cơ chế), HTTP manipulation (6 cơ chế), và network-layer (2 cơ chế).

Action masking: Environment tính mask $m(s) \in \{0, 1\}^{|A|}$ cho mỗi trạng thái. Agent chỉ được chọn action a nếu $m(s)[a] = 1$.



Hình 3.1: Kiến trúc hệ thống Hidden Defender.

3.2.3 Hàm phần thưởng R

Phần thưởng được tính dựa trên ba cổng kiểm tra: cổng IDS, cổng ngữ nghĩa, và cổng replay.

$$R(s,a,s') = \begin{cases} +10 & \text{if evaded AND semantics_ok} \\ -1 & \text{if detected AND semantics_ok} + \text{cost}(a) \\ -10 & \text{if semantics broken} \end{cases} \tag{3.1}$$

3.3 Thuật toán PPO

Hidden Defender sử dụng PPO (Schulman et al., 2017) với action masking. PPO tối ưu hóa clipped surrogate objective để ổn định học tập.

3.4 Surrogate Model

Surrogate mô phỏng ba bước của Snort:

1. **IP Defragmentation (Frag3)**: Ghép IP fragment, kiểm tra timeout 60s và gap/overlap anomaly.
2. **TCP Reassembly**: Ghép TCP segment theo sequence number.
3. **Rule Matching**: Parse 21,374 Snort rule và áp dụng lên payload đã reassemble.

Sau khi fix (P16c), surrogate khớp Suricata 100/100 test case.

Chương 4

Kết quả thực nghiệm

4.1 Thiết lập thực nghiệm

4.1.1 Môi trường

- Ubuntu 24.04 LTS, Python 3.11.9
- Stable-Baselines3 2.3.2 (PPO + masking)
- Snort 2.9.20, Suricata 7.0.3
- ET Open ruleset: 21,374 rules

4.1.2 Corpus

Corpus ban đầu: 1153 flow train, 40 flow test từ `botnet-capture-20110819-bot`. Phân tích sâu (P17) phát hiện:

Bảng 4.1: Thành phần corpus.

Nhóm	Train	Test
C2 HTTP (trojan-activity)	455 (39,5%)	16 (40%)
P2P DHT (policy-violation)	697 (60,5%)	24 (60%)

4.2 Kết quả chính

4.2.1 Oracle sweep

4.2.2 RL policy

PPO train 120 epoch (seed 42) trên surrogate, validate trên Snort:
RL đạt 16/40 = đúng bằng 16 flow C2-HTTP ⇒ 100% trên C2, 0% trên DHT.

Bảng 4.2: Kết quả oracle 680 query trên Snort 2.9.20.

Cơ chế	Flows evaded	Tỷ lệ
split_slow	23/40	57,5%
http_header_case	16/40	40%
split8/16/24	16/40	40%
Oracle	23/40	57,5%
Headroom	0 pp	

Bảng 4.3: Hiệu suất RL.

Method	Flows evaded	Tỷ lệ
Noop (baseline)	0/40	0%
Best single	23/40	57,5%
PPO policy	**16/40**	**40%**

Chương 5

Thảo luận

5.1 Tại sao headroom = 0?

Ba nguyên nhân:

1. Corpus không đa dạng (6 SID, 40 flow).
2. Action space bị giới hạn bởi protocol.
3. IDS nghiêm với frag3 anomaly detection.

5.2 Điểm mạnh

1. Đo headroom chính xác qua oracle.
2. Cross-engine validation (Snort + Suricata).
3. Phát hiện corpus framing (60% DHT).
4. Surrogate 100% agreement với Suricata.

5.3 Hạn chế

1. Corpus nhỏ (40 flow test).
2. Single-step MDP (không chaining).
3. Threat model hẹp (chỉ packet-level).

Chương 6

Kết luận

Nghiên cứu này chứng minh rằng **chất lượng surrogate và corpus quyết định thành công của RL trong IDS evasion**. Khi surrogate chính xác và corpus đại diện, RL có thể học được policy hiệu quả (100% trên C2-HTTP). Tuy nhiên, nếu headroom = 0, RL không thể vượt qua baseline.

Điều quan trọng không phải là "RL có hoạt động không", mà là "không gian hành động có đủ lớn để RL học policy phức tạp không". Trong trường hợp này, câu trả lời là **chưa** — cần corpus lớn hơn và đa dạng hơn.

Hướng phát triển:

- Corpus C2 thuần khiết từ 21 capture Stratosphere.
- Multi-step RL cho phép chaining cơ chế.
- Adversarial training: IDS học từ RL agent.

Tài liệu tham khảo

[1] Schulman, J., et al. (2017). Proximal policy optimization algorithms. arXiv:1707.06347.

[2] Stratosphere Laboratory. (2011). CTU-13 dataset. https://www.stratosphereips.org/datasets-ctu13

[3] Paxson, V., & Shankar, U. (2003). Active mapping: Resisting NIDS evasion. IEEE S&P.